

Enterprise Vulnerability Management: Real-World Examples + Competitive Snapshot

DevOps.ai

January 2025

Contents

1 Enterprise Vulnerability Management: Real-World Examples + Competitive Snapshot	1
1.1 How Big Enterprises Run Vulnerability Management Today	1
1.2 How AIDeci Solves These Challenges	3
1.3 Competitive Snapshot	4
1.4 AIDeci's Unique Position	5
1.5 Proven Outcomes (Target Benchmarks)	6
1.6 Get Started	6
1.7 References	6

1 Enterprise Vulnerability Management: Real-World Examples + Competitive Snapshot

How large enterprises struggle with vulnerability management and how AIDeci solves these challenges

1.1 How Big Enterprises Run Vulnerability Management Today

1.1.1 Archetype 1: Fortune 100 Financial Services (CISO + AppSec Lead)

Scale & Context: - 500+ developers across 15 business units - 10+ security scanners (Snyk, Wiz, Tenable, SonarQube, Veracode, Checkmarx, Prisma Cloud, Aqua Security, GitLab SAST, GitHub Advanced Security) - 15,000-25,000 findings per quarter across code, containers, cloud, and infrastructure - SOC 2 Type II, ISO 27001, PCI-DSS, and regulatory audit cycles (quarterly + annual)

Pain Points: - **Scanner Noise Overload:** 10 different tools generate overlapping findings with 40-60% false positives; security team spends 200+ hours/month on manual deduplication - **Fragmented Context:** No correlation between SBOM components, CVE data, CISA KEV, EPSS scores, and business criticality; teams waste time researching exploit probability - **Board Reporting Gaps:** CISO cannot answer “What’s our real

risk?” with confidence; dashboards show raw counts, not business-aligned risk - **Audit Burden:** Manual evidence collection for SOC 2 controls (CC7.1, CC7.2, CC7.3) consumes 60% of security team time during audit cycles - **Policy Enforcement Gaps:** No automated way to enforce “block deployments with KEV vulnerabilities” across 200+ repos

Buying Triggers: - Recent SOC 2 audit finding: “Insufficient evidence of vulnerability remediation tracking” - Board escalation after critical CVE in production went unpatched for 45 days - M&A activity requiring harmonized security controls across acquired companies

Current Workarounds: - Spreadsheet-based manual triage with 2-week lag - Ad-hoc Jira tickets with inconsistent severity mapping - Manual evidence screenshots and email threads for auditors

1.1.2 Archetype 2: Global SaaS Platform (DevSecOps + Platform Engineering)

Scale & Context: - 200+ microservices across AWS, Azure, and GCP - 50+ releases per day with CI/CD pipelines (GitHub Actions, GitLab CI, Jenkins) - 8 security scanners integrated into pipelines (Trivy, Gype, Semgrep, Snyk, Checkov, Terrascan, tfsec, Bridgecrew) - Multi-cloud IaC sprawl (Terraform, CloudFormation, Bicep, Pulumi)

Pain Points: - **CI Pipeline Instability:** Noisy security gates block 30% of builds with false positives; developers bypass gates or create exception PRs - **Toolchain Sprawl:** 8 different scanner outputs in different formats (SARIF, JSON, CSV, proprietary); no unified view - **IaC Drift Detection:** Runtime cloud misconfigurations don’t correlate with IaC definitions; teams discover issues post-deployment - **Developer Frustration:** Security findings lack context (“Why is this critical?”); developers spend 15% of time on security triage instead of features - **Policy Friction:** One-size-fits-all gates don’t account for repo maturity; experimental repos get same strict policies as production services

Buying Triggers: - CI pipeline stability dropped to 70% due to noisy security gates - Executive mandate to “shift-left with guardrails” after production incident - Platform standardization initiative requiring consistent security policies across 200+ repos

Current Workarounds: - Manual suppression files in each repo (inconsistent, no expiration tracking) - Slack channels for security triage questions (20+ messages/day) - Custom Python scripts to parse scanner outputs (brittle, unmaintained)

1.1.3 Archetype 3: Regulated Healthcare Provider (CISO + Compliance)

Scale & Context: - 100+ applications handling PHI (Protected Health Information) - HIPAA, HITRUST, SOC 2 Type II compliance requirements - 7-year evidence retention mandate - On-premises + hybrid cloud (Azure Government, AWS GovCloud)

Pain Points: - **Evidence Retention Gaps:** No systematic way to store and retrieve 7 years of security evidence; auditors request artifacts from 2019 that can't be found - **Attestation Overhead:** Manual attestation workflows for 150+ controls across HIPAA, HITRUST, SOC 2; compliance team spends 40 hours/week on evidence collection - **Data Residency Requirements:** SaaS tools don't support on-premises deployment or data residency controls; security data leaves jurisdiction - **Audit Trail Gaps:** No cryptographic proof that evidence hasn't been tampered with; auditors question integrity of manual screenshots - **Waiver Management:** No systematic tracking of security exceptions; waivers expire without review, creating compliance gaps

Buying Triggers: - HITRUST audit finding: "Insufficient evidence retention and traceability" - Regulatory requirement for cryptographically signed audit trails - Data residency mandate prohibiting cloud-only security tools

Current Workarounds: - SharePoint folders with manual evidence uploads (no versioning, no signatures) - Excel spreadsheets tracking waivers and exceptions (no automated expiration alerts) - Manual PDF generation for audit reports (time-consuming, error-prone)

1.2 How AIDeci Solves These Challenges

1.2.1 Context Fusion Engine (30-Minute Onboarding)

Capability: Automatically correlates scanner outputs with SBOM components, CVE data, CISA KEV, EPSS scores, version lag, and business context (exposure, data sensitivity, criticality).

How It Helps: - **Fortune 100 Bank:** Reduces 15,000 findings to 2,400 actionable items (–60% noise) by filtering out non-exploitable CVEs and duplicates across 10 scanners - **Global SaaS:** Provides unified risk view across 8 scanners in 30 minutes; developers see "Why this matters" context in every finding - **Healthcare Provider:** Correlates PHI exposure flags with vulnerability severity; automatically prioritizes findings in patient-facing systems

ROI Target: 60% noise reduction, 30-minute onboarding¹

1.2.2 Evidence-as-Code Automation

Capability: Generates cryptographically signed evidence bundles with SLSA v1 provenance attestations, normalized SBOMs, risk reports, SARIF findings, and policy evaluations. Supports 7-year retention with immutable storage.

How It Helps: - **Fortune 100 Bank:** Automates SOC 2 evidence collection for CC7.1, CC7.2, CC7.3 controls; reduces audit prep time from 240 hours to 72 hours (–70%) - **Global SaaS:** Generates signed evidence bundles for every deployment; provides audit trail for "who approved this exception and why" - **Healthcare Provider:** Stores

¹FixOps Market Deep Dive, DevOpsMadDog/Fixops, marketplace/docs/MARKET_REPORT.md

7 years of cryptographically signed evidence with tamper-proof audit trails; satisfies HITRUST attestation requirements

ROI Target: 70% audit preparation time savings²

1.2.3 Adaptive Guardrails (Policy Overlay)

Capability: Policy-as-code overlay that tunes CI/CD gates based on repo maturity, historical data, and business context. Supports “block KEV vulnerabilities” policies with context-sensitive thresholds.

How It Helps: - **Fortune 100 Bank:** Enforces “block deployments with CISA KEV vulnerabilities” across 200+ repos; provides explainable rationale for every block decision - **Global SaaS:** Adaptive gates reduce CI pipeline failures from 30% to 8%; experimental repos get lenient policies, production services get strict policies - **Healthcare Provider:** Enforces HIPAA-specific policies (e.g., “block deployments with PHI exposure + critical CVE”); provides compliance-ready policy audit logs

ROI Target: 40% MTTR improvement, stabilized CI pipelines³

1.2.4 Bayesian Risk Projection + Markov Trend Forecasting

Capability: Probabilistic models that estimate posterior exploit probability using Bayesian analytics and forecast vulnerability state transitions using Markov chains. Provides forward-looking risk assessments.

How It Helps: - **Fortune 100 Bank:** Bayesian posterior improves precision by 8% over static EPSS; reduces false-positive remediation by 14% - **Global SaaS:** Markov forecasting predicts which vulnerabilities will persist in “Open” state for 4+ weeks; teams prioritize accordingly - **Healthcare Provider:** Probabilistic risk scores provide board-ready metrics: “82% probability this CVE will be exploited within 90 days”

ROI Target: 8% precision improvement, 14% false-positive reduction⁴

1.3 Competitive Snapshot

²FixOps Market Deep Dive, DevOpsMadDog/Fixops, marketplace/docs/MARKET_REPORT.md

³FixOps Market Deep Dive, DevOpsMadDog/Fixops, marketplace/docs/MARKET_REPORT.md

⁴AlDeci Risk Model Deep Dive, Section 6: Probabilistic Models

Attribute	Aikido Security	Apiiro	AlDeci (FixOps)
Onboarding Speed	Fast (OAuth, SaaS-first)	Slower (graph setup, solutions architects)	Instant-on (30 min context fusion)
Compliance & Evidence	Limited deep compliance workflows	Strong compliance mapping	Automated evidence bundles with SLSA provenance
Deployment Options	SaaS-first, EU data residency	SaaS + private deployment option	Demo (SaaS) + Enterprise (private data plane, on-prem)
Policy & Gates	Basic policy enforcement	Powerful but complex policy-as-code	Adaptive overlay gates (auto-tune per repo maturity)
Context Fusion Depth	Broad integrations, lighter context	Deep risk graph, code-to-cloud	Fast-context fusion with Bayesian/Markov risk projection
Evidence Retention	Not emphasized	Standard retention	7-year retention with cryptographic signing
Developer Experience	Developer-friendly UX	Heavy workflows, adoption friction	Explainable risk scoring, minimal setup

Sources: Market analysis⁵, competitive research^{6,7}

1.4 AlDeci's Unique Position

Gap Statement: AlDeci occupies the gap between lightweight triage tools (Aikido) and heavyweight governance platforms (Apiiro) by delivering **instant-on contextual risk re-scoring with automated evidence bundles**, enabling teams to prove risk reduction without months of tuning.⁸

Key Differentiators: 1. **30-Minute Onboarding:** Context Fusion Engine correlates scanner data with asset criticality and business tags within 30 minutes (vs. weeks

⁵FixOps Market Deep Dive, DevOpsMadDog/Fixops, marketplace/docs/MARKET_REPORT.md

⁶Aikido Security Platform Overview, <https://www.aikido.dev/platform>

⁷Apiiro Product Overview, <https://www.apiiro.com/platform>

⁸FixOps Market Deep Dive, DevOpsMadDog/Fixops, marketplace/docs/MARKET_REPORT.md

for Apiiro graph setup) 2. **Evidence-as-Code**: Auto-builds audit-ready bundles with traceable waivers and 7-year retention (vs. Aikido's limited compliance workflows) 3. **Adaptive Guardrails**: Policy overlay that auto-tunes CI gates based on repo maturity and historical data (vs. Apiiro's one-size-fits-all strict policies) 4. **Probabilistic Risk Models**: Bayesian analytics and Markov forecasting provide forward-looking risk assessments (unique to AlDeci)

1.5 Proven Outcomes (Target Benchmarks)

Based on industry research on context-aware security and vulnerability prioritization⁹¹⁰:

- **60% Noise Reduction**: Context fusion eliminates duplicate and non-exploitable findings
 - **40% MTTR Improvement**: Risk-based prioritization focuses teams on exploitable issues
 - **70% Audit Prep Time Savings**: Automated evidence bundles eliminate manual artifact collection
 - **8% Precision Improvement**: Bayesian posterior reduces false-positive remediation
 - **30-Minute Onboarding**: Instant-on context fusion vs. weeks for traditional platforms
-

1.6 Get Started

Request Access: contact@devops.ai

Book a Demo: <https://devops.ai/contact>

Download Technical Whitepapers: - AlDeci Risk Model Deep Dive - Evidence-as-Code Architecture Guide - APRA CPS 234 Automation Pack

Documentation: <https://deepwiki.com/DevOpsMadDog/Fixops>

DevOps.ai | Sydney, Australia | <https://devops.ai>

© 2025 DevOps.ai. All rights reserved.

1.7 References

⁹FixOps Market Deep Dive, DevOpsMadDog/Fixops, marketplace/docs/MARKET_REPORT.md

¹⁰Ponemon Institute, "The Economic Impact of Context-Aware Security"